

KHOA CÔNG NGHỆ THÔNG TIN
BỘ MÔN KTHT&MMT

ĐỀ THI KẾT THÚC HỌC PHẦN
Môn: An toàn bảo mật thông tin
Thời gian làm bài 60 phút

Câu 1. Thuật toán DES sử dụng một cấu trúc đặc biệt để thực hiện quá trình mã hóa và giải mã. Cấu trúc này giúp biến đổi dữ liệu theo từng vòng mà không cần phải thay đổi thuật toán khi giải mã. Cấu trúc đó được gọi là gì?

- A. Mạng hoán vị (Permutation Network).
- B. Mạng neuron mật mã (Cryptographic Neural Network).
- C. Mạng nhân tử hỗn hợp (Mixed Multiplicative Network).
- D. Mạng Feistel (Feistel Network).

Câu 2. Cho bản rõ M = “BOHEMIAN RHAPSODY”, sử dụng mã hóa với mã Caesar với $K = 7$, bản mã C là:

- A. ERKHPLDQ UKDSVRGB
- B. FSLIQMER VLETWSHC
- C. HUNKSOGT XNGVYUJE
- D. IVOLTPHU YOHWZVKF

Câu 3. Cho bản mã C = “LW LV D VXQQB GDB”, sử dụng mã hóa với mã Caesar với $K = 3$, bản rõ M là:

- A. IT IS A SNOWY DAY
- B. IT IS A RAINY DAY
- C. IT IS A SUNNY DAY
- D. IT IS A CLOUDY DAY

Câu 4. Mật mã gồm các lĩnh vực con nào: (chọn nhiều đáp án)

- A. Lập mã.
- B. Sử dụng mã.
- C. Thám mã.
- D. Lập trình mã.

Câu 5. Để đảm bảo tính bí mật của bản tin M được gửi đi trên mạng công khai, người ta thường sử dụng phương pháp nào:

- A. Gửi bản tin vào thời gian khuya.
- B. Gửi bản tin ở nơi không có người qua lại.
- C. Gửi bản tin đã được mã hóa.
- D. Gửi thẳng bản rõ trên kênh công khai.

Câu 6. Độ an toàn của hệ mã được định nghĩa là:

- A. Là độ khó hiểu, phức tạp của thuật toán mật mã.
- B. Là khả năng lập trình được trên phần cứng.
- C. Là khả năng chống lại thiên tai hỏa hoạn khi có trường hợp xảy ra.
- D. Là khả năng đứng vững của hệ mật mã trước nguy cơ tấn công thám mã.

Câu 7. Trong thuật toán DES, các hộp thế S-box được thiết kế đặc biệt để chống lại loại tấn công nào sau đây?

- A. Tấn công vét cạn (Brute-force attack).
- B. Tấn công từ chối dịch vụ (Denial of Service - DoS).
- C. Tấn công phân tích mật mã tuyến tính (Linear cryptanalysis).
- D. Tấn công giả mạo danh tính (Identity spoofing).

Câu 8. Cho bản rõ M = “JUDE BELLINGHAM”, sử dụng mã hóa với mã Vigenere với K = HUCE, bản mã C là:

- A. QOFI IYNPPHILHG
- B. OZIJ GJQQNSLMFR
- C. QBKL ILSSPUNOHT
- D. RCLM JMTTQVOPIU

Câu 9. Cho bản mã C = “PN KW H MPSPDS FEF”, sử dụng mã hóa với mã Vigenere với K = HUCE, bản rõ M là:

- A. IT IS A SNOWY DAY
- B. IT IS A RAINY DAY
- C. IT IS A SUNNY DAY
- D. IT IS A CLOUDY DAY

Câu 10. Nếu bản rõ có độ dài là 10, thì không gian khóa khi sử dụng mật mã Vigenere (với trường hợp sử dụng bảng chữ cái tiếng Anh) là bao nhiêu?

- A. 26×10
- B. 10^{26}
- C. 26^{10}
- D. 25^{10}

Câu 11. Cho bản rõ M = “HUCE”, sử dụng mã hóa với mã Vernam với K = “EOPF”, bản mã C là:

- A. LIRJ
- B. LPOO
- C. EZZZ
- D. EZTZ

Câu 12. Giả sử Alice và Bob sử dụng hệ mã Vernam (OTP) để mã hóa các thông điệp có độ dài 100 ký tự, mỗi ký tự được biểu diễn bằng một trong 26 chữ cái từ A đến Z. Hỏi không gian khóa (số lượng khóa có thể có) trong hệ mã này là bao nhiêu?

- A. 100^{26}
- B. 26^{100}
- C. $26!$
- D. $100.26!$

Câu 13. Hỏi có bao nhiêu cặp khóa (a, b) hợp lệ nếu Bob sử dụng bảng chữ cái có $p = 29$ ký tự thay vì 26?

- A. 420
- B. 812
- C. 840
- D. 750

Câu 14. Bob sử dụng hệ mật Affine Cipher để mã hóa một thông điệp. Giả sử Bob chọn khóa $k = (5; 8)$, và muốn mã hóa chuỗi $M = \text{"NHATDUONG"}$. Hỏi bản mã thu được là gì?

- A. "VRIZXEAVM"
- B. "ZKQOVYJNG"
- C. "FMRBZJPKD"
- D. "XWLUACNOY"

Câu 15. Nguyên lý Confusion khi thiết kế mật mã khóa bí mật (mật mã khóa đối xứng) có ý nghĩa là:

- A. Mỗi bit của khóa K đều ảnh hưởng đến giá trị của hầu hết các bit trong bản mã C . Do đó, mối quan hệ giữa khóa K và bản mã trở nên rất khó xác định.
- B. Mỗi bit của bản rõ M đều tác động đến giá trị của trên 50% số bit trong bản mã C và ngược lại. Do đó, mối quan hệ giữa M và C cũng rất khó xác định.
- C. Mỗi bit của bản rõ M và khóa K đều tác động đến giá trị của trên 50% số bit trong bản mã C và ngược lại. Do đó, mối quan hệ giữa M và C cũng rất khó xác định.
- D. Mỗi bit của bản rõ M và khóa K không có tác động đến giá trị của bản mã C .

Câu 16. Đối với mã khóa bí mật (mã khóa đối xứng), chế độ mã hóa nào sau đây có thể lập trình song song để tăng tốc độ mã hóa và giải mã:

- A. CBC.
- B. ECB.
- C. Không có chế độ nào.
- D. Cả hai chế độ trên.

Câu 17. Trong mật mã khóa công khai, mỗi chủ thể sử hữu:

- A. 1 khóa bí mật duy nhất.
- B. 1 cặp khóa (1 bí mật, 1 công khai).

- C. 1 khóa công khai duy nhất.
- D. Số lượng khóa phụ thuộc vào hệ mã.

Câu 18. So với mật mã khóa đối xứng, tốc độ của hệ mật khóa công khai:

- A. Nhanh hơn.
- B. Chậm hơn.
- C. Bằng nhau.
- D. Lúc nhanh hơn, lúc chậm hơn.

Câu 19. Cho hệ mã RSA, với $N = p * q$, trong đó $p = 61, q = 53, e = 17$. Khi đó, khóa bí mật d là:

- A. $d = e^{-1} \mod \varphi(N) = 2092$.
- B. $d = e^{-1} \mod \varphi(N) = 3127$.
- C. $d = e^{-1} \mod \varphi(N) = 3233$.
- D. $d = e^{-1} \mod \varphi(N) = 413$.

Câu 20. Trong hệ mật RSA, Alice muốn gửi một thông điệp an toàn đến Bob. Alice sử dụng khóa công khai của Bob để mã hóa thông điệp. Giả sử khóa công khai của Bob có $N = p \times q$, trong đó $p = 61, q = 53$, và $e = 17$. Alice muốn gửi bản rõ $M = 123$. Hỏi bản mã C mà Alice thu được sau khi mã hóa là bao nhiêu?

- A. Nhận được kết quả là 855.
- B. Nhận được kết quả là 2201.
- C. Nhận được kết quả là 1975.
- D. Nhận được kết quả là 3120.

Câu 21. Bob là một nhà nghiên cứu bảo mật và đang thử nghiệm hệ mật RSA trong một hệ thống truyền thông an toàn. Bob nhận được một bản mã $C = 1390$, được mã hóa bằng khóa công khai của hệ thống. Biết rằng hệ thống sử dụng các tham số RSA sau: $p = 47, q = 71, e = 13$ (số mũ công khai). Để giải mã và tìm lại bản rõ M , Bob cần tính toán khóa bí mật d và sử dụng công thức giải mã RSA. Hãy giúp Bob tìm giá trị của M .

- A. 2111.
- B. 513
- C. 1099
- D. 1998

Câu 22. Trong hạ tầng khóa công khai (PKI), nếu một chứng chỉ số bị thu hồi do bị đánh cắp hoặc không còn hợp lệ, hệ thống nào chịu trách nhiệm thông báo và xác minh tình trạng chứng chỉ đó?

- A. Online Certificate Status Protocol (OCSP) và Certificate Revocation List (CRL).
- B. Domain Name System Security Extensions (DNSSEC).
- C. Transport Layer Security (TLS) Handshake.
- D. Elliptic Curve Digital Signature Algorithm (ECDSA).

Câu 23. Trong quá trình tạo chữ ký số sử dụng thuật toán RSA, ta sử dụng:

- A. Khóa công khai.
- B. Khóa bí mật.
- C. Đồng thời cả 2 khóa.
- D. Không sử dụng khóa nào cả.

Câu 24. Đối với mã hóa DES, trong các phát biểu sau phát biểu nào là sai?

- A. DES sử dụng khóa có chiều dài 64 bits.
- B. Dữ liệu được mã hóa trong các khối có chiều dài 64 bits.
- C. S-box là một hàm thay thế không tuyến tính làm tăng độ phức tạp của phép biến đổi.
- D. DES dùng bộ tạo khóa để tạo ra các khóa con dùng cho mỗi vòng và chúng có chiều dài là 48.

Câu 25. Trong các hàm dưới đây, đâu là hàm băm:

- A. RSA-2048.
- B. AES-512.
- C. 3-DES.
- D. MD5.

Câu 26. Giả sử một hàm băm mật mã H có đầu ra dài 256 bit. Trong trường hợp xấu nhất, số lần băm tối đa cần thiết để tìm hai đầu vào khác nhau nhưng cho cùng một giá trị băm (tấn công va chạm - collision attack) theo lý thuyết là bao nhiêu?

- A. 2^{256} .
- B. 2^{128} .
- C. 2^{64} .
- D. 256!.

Câu 27. Mã độc thường tác động đến hệ thống Windows như thế nào?

- A. Tạo khóa trong Registry để khởi động cùng HĐH.
- B. Mã hóa các tệp dữ liệu.
- C. Xóa các file định dạng pdf.
- D. Tự xóa bản thân tệp tin gốc sau khi được thực thi.

Câu 28. Tại sao cần sao lưu/phục hồi (Backup/Restore) dữ liệu ?

- A. Cần sao lưu tới một vị trí ổ đĩa khác, vì có khi ổ đĩa hiện hành đột nhiên ngừng hoạt động. Nên theo định kỳ copy thành một bản offline.
- B. Bảo vệ dữ liệu khi bị xóa, bị mã hoá ...
- C. Lấy lại dữ liệu một cách dễ dàng bằng cách Restore các files đã được Backup tự động trước đó.
- D. Tất cả các phương án trên.

Câu 29. Một công ty có 100 máy tính laptop, mỗi máy giá 20 triệu đồng. Trung bình cứ 02 năm lại xảy ra sự cố bị mất một máy. Nếu chi phí kiểm soát là 2 triệu/năm, thì rủi ro giảm từ 02 năm xảy ra sự cố một lần xuống còn 04 năm xảy ra một lần. Số tiền thực sự Công ty đã tiết kiệm được là bao nhiêu triệu (mỗi năm)?

- A. 1
- B. 2
- C. 3
- D. 4

Câu 30. Câu lệnh: `<script>alert(document.cookie)</script>` thuộc loại tấn công nào sau đây?

- A. XSS.
- B. SQL injection.
- C. CSRF.
- D. DoS.

Câu 31. A đang viết một email nhạy cảm cho B bên ngoài mạng cục bộ. A đã chọn sử dụng PKI để bảo mật thư của mình và đảm bảo chỉ B mới có thể đọc được email nhạy cảm. Quá trình mã hóa và giải mã thông điệp diễn ra ở lớp nào của lớp OSI?

- A. Application.
- B. Transport.
- C. Session.
- D. Presentation.

Câu 32. Chương trình nào sau đây thường nhắm tới các sản phẩm Microsoft Office?

- A. Polymorphic virus.
- B. Multipart virus.
- C. Macro virus.
- D. Stealth virus.

Câu 33. Sau khi hacker khai thác thành công lỗ hổng, chúng thường duy trì kiểm soát lâu dài trên hệ thống bằng cách nào sau đây?

- A. Tải và thực thi mã độc trên máy mục tiêu
- B. Vô hiệu quá tính năng cập nhật bản vá trên máy mục tiêu
- C. Vô hiệu hóa Anti-virus trên hệ thống
- D. Tắt tường lửa trên hệ thống

Câu 34. Thuật ngữ nào mô tả mức độ rủi ro còn lại sau khi các lỗ hổng được phân loại và các biện pháp đối phó đã được triển khai?

- A. Residual risk (Rủi ro tồn dư)
- B. Impact risk (Rủi ro tác động)
- C. Deferred risk (Rủi ro trì hoãn)
- D. Inherent risk (Rủi ro cố hữu)

Câu 35. Để truy cập trang web ngân hàng, lưu lượng truy cập từ máy trạm phải vượt qua tường lửa. Bạn đã được yêu cầu xem lại cấu hình tường lửa để đảm bảo rằng các máy trạm trong mạng 10.10.10.0/24 chỉ có thể truy cập trang web ngân hàng 10.20.20.1 bằng HTTPS. Quy tắc tường lửa nào sau đây đáp ứng yêu cầu này?

- A. if (source matches 10.10.10.0/24 and destination matches 10.20.20.1 and port matches 443) then permit
- B. if (source matches 10.10.10.0/24 and destination matches 10.20.20.1 and port matches 80 or 443) then permit
- C. if (source matches 10.20.20.1 and destination matches 10.10.10.0/24 and port matches 443) then permit
- D. if (source matches 10.10.10.0 and destination matches 10.20.20.1 and port matches 443) then permit

Câu 36. A là một chuyên gia bảo mật, đang sử dụng hệ mật RSA để thực hiện ký số một thông điệp quan trọng. Để đảm bảo tính toàn vẹn và xác thực của dữ liệu, A sử dụng các tham số RSA như sau: $p = 17, q = 23, e_A = 3$, bản rõ $M = [198\ 95\ 119]$. Hỏi chữ ký số mà A tạo ra sẽ là gì?

- A. $Sig = [260\ 303\ 340]$.
- B. $Sig = [361\ 298\ 153]$.
- C. $Sig = [155\ 304\ 317]$.
- D. $Sig = [153\ 198\ 153]$.

Câu 37. Bạn đang làm Nhà phân tích bảo mật trong một công ty XYZ sở hữu toàn bộ phạm vi mạng con 23.0.0.0/8 và 192.168.0.0/8. Trong lúc theo dõi dữ liệu, bạn nhận thấy có rất nhiều kết nối ra ngoài. Bạn thấy rằng IP thuộc sở hữu của XYZ (internal) và IP riêng (private IP) đang liên lạc với một IP công cộng (IP public) duy nhất. Sau khi phân tích sâu hơn, bạn phát hiện ra rằng IP công cộng (IP public) này là IP nằm trong blacklist và các thiết bị liên lạc nội bộ đã bị nhiễm độc. Kịch bản trên mô tả loại tấn công nào?

- A. Botnet Attack
- B. Spear Phishing Attack
- C. Advanced Persistent Threats
- D. Rootkit Attack

Câu 38. Bạn đang xem xét bảo mật tài liệu trên máy chủ tài liệu đám mây riêng của mình. Bạn nhận thấy nhân viên trong bộ phận Bán hàng đã được cấp toàn quyền cho tất cả các tài liệu dự án. Nhân viên bán hàng chỉ nên đọc quyền đối với tất cả các tài liệu dự án. Nguyên tắc bảo mật nào đã bị vi phạm?

- A. Tách nhiệm vụ
- B. Đặc quyền tối thiểu
- C. Luân chuyển công việc
- D. Toàn vẹn

Câu 39. Sau khi tiến hành kiểm toán bảo mật, bạn thông báo cho chủ sở hữu mạng rằng bạn đã phát hiện ra không được mã hóa mạng không dây. Khách hàng của bạn hỏi làm thế nào tốt nhất để bảo đảm lưu lượng không dây. Điều nào sau đây là mã hóa mạng không dây an toàn nhất?

- A. WEP
- B. WPA
- C. WPA2
- D. RC4

Câu 40. Địa chỉ IP hoạt động ở tầng nào trong mô hình mạng OSI?

- A. Transport
- B. Data Link
- C. Session
- D. Network

Câu 41. Quản trị viên mạng, Justin, phải cấp cho nhiều bộ phận khác nhau quyền truy cập vào thư mục Corp_Pol và cấp cho các bộ phận khác đọc và ghi quyền truy cập vào thư mục Current_Projects. Chiến lược nào nên Justin tuyển dụng?

- A. Thêm tất cả người dùng bộ phận vào ACL thư mục dùng chung với các quyền thích hợp.
- B. Tạo một nhóm, thêm thành viên và thêm nhóm vào ACL thư mục phù hợp quyền.
- C. Tạo nhóm người dùng và nhóm quản trị viên với các thành viên chính xác. Thêm các nhóm vào ACL thư mục với các quyền thích hợp.
- D. Tạo một nhóm cho mỗi bộ phận và thêm thành viên vào các nhóm. Thêm các nhóm vào thư mục ACL với các quyền thích hợp.

Câu 42. Trong một cuộc họp bảo mật CNTT, chủ đề về khóa tài khoản sẽ xuất hiện. Khi bạn đề xuất tất cả tài khoản người dùng bị khóa trong 30 phút sau ba lần đăng nhập không chính xác, đồng nghiệp Phil của bạn nói rằng đây là một vấn đề nghiêm trọng khi áp dụng vào tài khoản hành chính. Phil có thể đề cập đến những loại vấn đề nào?

- A. Tấn công từ điển có thể đột nhập vào tài khoản hành chính.
- B. Tài khoản hành chính được nhiều kẻ tấn công tìm kiếm.
- C. Tài khoản hành chính được đặt vào nhóm hành chính.
- D. Các cuộc tấn công DoS có thể khiến các tài khoản quản trị không thể sử dụng được.

Câu 43. Để tuân thủ các nguyên tắc bảo mật mới của công ty, các văn phòng chi nhánh của bạn phải theo dõi chi tiết về việc truy cập các trang web. Bạn nên cài đặt cái gì?

- A. VPN
- B. Máy chủ proxy
- C. Tường lửa lọc gói
- D. NIDS

Câu 44. Sau khi kiểm tra nhật ký cẩn thận, bạn nhận ra ai đó đã xâm nhập vào mạng không dây được bảo mật WEP của bạn mạng. Bạn có thể làm gì để bảo mật lưu lượng không dây?

- A. Sử dụng doanh nghiệp WPA2.
- B. Sử dụng WPA2 PSK.
- C. Vô hiệu hóa phát SSID.
- D. Thay đổi tên SSID

Câu 45. Một nhân viên bị nghi ngờ tiết lộ bí mật của công ty với đối thủ cạnh tranh. Sau khi thu giữ máy tính xách tay của nhân viên, các nhà phân tích pháp y thông báo rằng có một số hình ảnh cá nhân trên máy tính xách tay đã được gửi qua email cho bên thứ ba trên Internet. Khi nhà phân tích so sánh giá trị băm của các hình ảnh cá nhân trên ổ cứng với những gì được tìm thấy trong hộp thư của nhân viên, các giá trị băm không khớp. Nhân viên đã chia sẻ bí mật công ty như thế nào?

- A. Chữ kí số
- B. Steganography
- C. MP3Stego
- D. Whaling

Câu 46. Phishing attack là gì?

- A. Một loại cuộc tấn công mạng để lấy thông tin cá nhân bằng cách giả mạo danh tính và gửi email hoặc tin nhắn để lừa người dùng.
- B. Một phần mềm độc hại tự nhân bản và lan truyền qua email để xâm nhập vào hệ thống mạng.
- C. Một loại virus tấn công vào trình duyệt web khiến người dùng bị chuyển hướng đến các trang web giả mạo.
- D. Một kỹ thuật bảo mật để ngăn chặn việc truy cập vào các trang web độc hại.

Câu 47. Các nhà phát triển web tại công ty của bạn đang thử nghiệm mã trang web mới nhất của họ trước khi đi vào hoạt động để đảm bảo rằng nó hoạt động hiệu quả và an toàn. Trong quá trình thử nghiệm, họ cung cấp các URL không đúng định dạng với các tham số bất thường bổ sung cũng như sự phong phú của dữ liệu ngẫu nhiên. Thuật ngữ nào mô tả hành động của họ?

- A. Cross-site scripting (XSS)
- B. Fuzzing
- C. Vá lỗi
- D. Debugging

Câu 48. Bạn đang kiểm tra một hệ thống của một người dùng sau khi cô ấy phàn nàn về tốc độ sử dụng Internet chậm hơn thường ngày. Sau khi phân tích hệ thống, bạn nhận thấy rằng địa chỉ MAC của cổng mạng định trong bộ đệm ARP đang tham chiếu sai địa chỉ MAC. Kiểu tấn công nào đã xảy ra?

- A. Brute force
- B. DNS poisoning
- C. Buffer overflow
- D. ARP poisoning

Câu 49. Giả sử một hệ thống có thể thử $5 \cdot 10^9$ (5 tỷ) khóa mỗi giây để thực hiện tấn công vét cạn vào DES. Hỏi thời gian tối đa cần để thử toàn bộ không gian khóa của DES là bao nhiêu?

- A. Khoảng 83 phút.
- B. Khoảng 83 năm.
- C. Khoảng 83 giờ.
- D. Khoảng 83 ngày.

Câu 50. Cách tiếp cận mật mã nào sử dụng các điểm trên một đường cong để xác định các cặp khóa công khai và riêng tư?

- A. RSA
- B. DES

- C. ECC
- D. PKI

Câu 51. Pharming là kiểu tấn công vào?

- A. Máy chủ web
- B. Máy chủ cơ sở dữ liệu của trang web
- C. Máy chủ và máy khách web
- D. Máy khách/ trình duyệt web

TRƯỞNG BỘ MÔN
(Ký và ghi rõ họ tên)

TS. Lê Thị Thùy Dương

Hà Nội, ngày 19 tháng 05 năm 2025
GIẢNG VIÊN RA ĐỀ

ThS. Nguyễn Việt Nhật
TS. Nguyễn Mạnh Thắng
KS. Nguyễn Trần Hải